

AI Agent Assurance Report

Control Assurance across NIST AI RMF, ISO/IEC 42001, and OWASP LLM Top 10

Organization	Acme Corp (synthetic)
Assessment scope	Production AI Agent Fleet
Agents assessed	3
Report date	July 07, 2026
Framework basis	NIST AI RMF 1.0 ISO/IEC 42001:2023 OWASP LLM Top 10

Fleet assurance score	Critical findings	High findings
28/100	7	13

This assessment evaluates deployed AI agents against a consolidated control set spanning three governance frameworks. Scoring is severity-weighted: a single critical failure (e.g. destructive access to regulated data, or absent action logging) materially lowers an agent's assurance score. Agents scoring below 90 carry gaps that should be remediated before broader deployment.

Executive summary — fleet scorecard

Agent	Environment	Score	Grade	Crit	High	Med
claims-triage-agent	production	0	F	3	6	2
customer-support-agent	production	35	F	2	4	3
devops-assistant-agent	production	48	D	2	3	1

claims-triage-agent

Environment: production | Assurance score: **0/100** | F - Not fit for production

11 finding(s), highest severity first:

CRITICAL	AAC-ACCESS-02 — No destructive permissions over sensitive data
Evidence	Destructive permissions (incl. wildcard supersets) on sensitive data: s3:* on *; dynamodb:* on *
Business risk	Delete/overwrite permissions on PHI/PII/sensitive stores let an autonomous or manipulated agent cause irreversible data loss or integrity compromise. Wildcard grants count — 's3:*' is a superset of every destructive S3 action.
Remediation	Remove Delete*/Put* actions and service wildcards on sensitive resources. Grant read-only where the workflow allows; route writes through a reviewed service, not the agent.
Mapped controls	NIST AI RMF: MANAGE-2.1, MEASURE-2.6 • ISO 42001: A.9.4 (Intended use of the AI system), A.7.4 (Quality of data for AI systems) • OWASP: LLM06: Excessive Agency, LLM02: Sensitive Information Disclosure
CRITICAL	AAC-LOG-01 — Agent action tracing is enabled
Evidence	Agent action tracing is disabled — invocations are not auditable.
Business risk	Without a complete action trace you cannot reconstruct what the agent did. This defeats incident response, audit, and accountability entirely.
Remediation	Enable full action/tool-invocation tracing to a durable log sink (e.g. CloudTrail + agent trace) before production use.
Mapped controls	NIST AI RMF: MEASURE-2.8, MANAGE-4.1 • ISO 42001: A.6.2.8 (AI system recording of event logs), A.6.2.6 (AI system operation and monitoring) • OWASP:
CRITICAL	AAC-OVS-01 — Human approval gates high-risk actions
Evidence	High-risk actions run without human approval: deny_claim, approve_payment.
Business risk	High-impact actions (payments, deletions, external comms) executed with no human checkpoint remove the accountability the EU AI Act and NIST require.
Remediation	Define the set of high-risk actions and require documented human approval (HITL) before the agent executes any of them.
Mapped controls	NIST AI RMF: MANAGE-2.3, GOVERN-1.4 • ISO 42001: A.9.2 (Processes for responsible use — human oversight), A.9.3 (Objectives for responsible use of AI system) • OWASP: LLM06: Excessive Agency
HIGH	AAC-ACCESS-01 — Agent execution role avoids wildcard permissions
Evidence	Wildcard actions granted to agent role: dynamodb:*, s3:*
Business risk	An agent role granting '*' or 'service:*' actions violates least privilege. Because agents act autonomously, an over-broad role converts a single prompt injection into arbitrary account actions.
Remediation	Scope the agent role to the explicit set of actions required for its task. Replace wildcards with enumerated actions and resource ARNs.
Mapped controls	NIST AI RMF: MANAGE-2.1, GOVERN-1.2 • ISO 42001: A.9.4 (Intended use of the AI system), Clause 8.1 (Operational planning & control) • OWASP: LLM06: Excessive Agency

HIGH	AAC-DATA-01 — Explicit data boundary is declared
Evidence	Agent has no declared data boundary (unrestricted data access).
Business risk	Governance requires knowing exactly which data an agent may touch. An unrestricted agent cannot be assessed for data-handling compliance.
Remediation	Define an explicit data boundary: allowed classifications and source systems. Default-deny any data domain not enumerated.
Mapped controls	NIST AI RMF: MAP-4.1, GOVERN-1.3 • ISO 42001: A.4.3 (Data resources), A.9.4 (Intended use of the AI system) • OWASP: LLM02: Sensitive Information Disclosure
HIGH	AAC-DATA-02 — Lawful processing basis for PII/PHI
Evidence	Agent can reach PII/PHI but declares no processing basis (GDPR Art.6 / HIPAA).
Business risk	If the agent can reach personal or health data — declared or not — a documented processing basis (GDPR Art.6 / HIPAA permitted use) is a hard compliance requirement.
Remediation	Record the lawful/processing basis for each sensitive data class the agent can reach, or remove that class from the agent's boundary and resources.
Mapped controls	NIST AI RMF: MAP-4.1, GOVERN-1.1 • ISO 42001: A.7.3 (Acquisition of data — data rights), A.2.3 (Alignment with other organisational policies) • OWASP: LLM02: Sensitive Information Disclosure
HIGH	AAC-RES-01 — Input guardrails against prompt injection
Evidence	No input filtering / injection guardrail configured (OWASP LLM01).
Business risk	Prompt injection is the top LLM risk. An agent with tool access and no input filtering can be steered into unintended actions by hostile input.
Remediation	Configure input guardrails (e.g. Bedrock Guardrails) with injection/jailbreak filters and denied-topic policies scoped to the agent's role.
Mapped controls	NIST AI RMF: MEASURE-2.7, MANAGE-2.2 • ISO 42001: A.6.2.6 (AI system operation and monitoring — AI-specific threats), A.6.2.2 (AI system requirements and specification) • OWASP: LLM01: Prompt Injection
HIGH	AAC-RES-02 — Agent output validated before downstream execution
Evidence	Agent output drives downstream actions with no output validation (OWASP LLM05).
Business risk	When agent output triggers downstream actions, treating it as trusted lets a manipulated model inject commands/queries into other systems. Undeclared downstream execution is assumed present (fail-closed).
Remediation	Validate, encode, or schema-constrain agent output before it reaches downstream executors (DB, shell, API), or explicitly declare the absence of downstream execution.
Mapped controls	NIST AI RMF: MEASURE-2.7, MANAGE-2.2 • ISO 42001: A.6.2.6 (AI system operation and monitoring), A.6.2.2 (AI system requirements and specification) • OWASP: LLM05: Improper Output Handling
HIGH	AAC-OVS-02 — Kill switch / pause mechanism exists
Evidence	No documented kill switch / pause mechanism for the agent.
Business risk	Operators must be able to stop a misbehaving agent immediately. No kill switch means no bounded blast radius.

Remediation	Implement and document a tested mechanism to pause/disable the agent and revoke its credentials on demand.
Mapped controls	NIST AI RMF: MANAGE-2.3, MANAGE-4.1 • ISO 42001: A.9.2 (Processes for responsible use — pause/stop conditions), A.6.2.6 (AI system operation and monitoring) • OWASP: LLM06: Excessive Agency

MEDIUM

AAC-LC-01 — Model version is pinned

Evidence	Model version not pinned (=‘latest’) — decisions not reproducible.
Business risk	A ‘latest’ model reference means the decision-making system can change silently. Governance requires reproducibility of which model produced which decision.
Remediation	Pin the agent to a specific model id and version. Promote new versions only through the change-review process.
Mapped controls	NIST AI RMF: MAP-2.3, MANAGE-4.1 • ISO 42001: A.4.4 (Tooling resources — reproducibility), A.6.2.5 (AI system deployment) • OWASP: LLM03: Supply Chain

MEDIUM

AAC-LC-02 — Model/prompt changes go through review

Evidence	No change-review process for model/prompt updates (uncontrolled drift risk).
Business risk	Uncontrolled prompt/model changes are drift. A documented review gate is the AI-system equivalent of change management.
Remediation	Require documented review/approval for model and system-prompt changes before they reach production.
Mapped controls	NIST AI RMF: MANAGE-4.1, GOVERN-1.5 • ISO 42001: A.6.2.5 (AI system deployment — release criteria), A.6.1.3 (Processes for responsible design & development) • OWASP:

customer-support-agent

Environment: production | Assurance score: **35/100** | F - Not fit for production

9 finding(s), highest severity first:

CRITICAL AAC-ACCESS-02 — No destructive permissions over sensitive data	
Evidence	Destructive permissions (incl. wildcard supersets) on sensitive data: s3:PutObject on *; s3:DeleteObject on *
Business risk	Delete/overwrite permissions on PHI/PII/sensitive stores let an autonomous or manipulated agent cause irreversible data loss or integrity compromise. Wildcard grants count — 's3:*' is a superset of every destructive S3 action.
Remediation	Remove Delete*/Put* actions and service wildcards on sensitive resources. Grant read-only where the workflow allows; route writes through a reviewed service, not the agent.
Mapped controls	NIST AI RMF: MANAGE-2.1, MEASURE-2.6 • ISO 42001: A.9.4 (Intended use of the AI system), A.7.4 (Quality of data for AI systems) • OWASP: LLM06: Excessive Agency, LLM02: Sensitive Information Disclosure
CRITICAL AAC-OVS-01 — Human approval gates high-risk actions	
Evidence	High-risk actions run without human approval: issue_refund, send_customer_email.
Business risk	High-impact actions (payments, deletions, external comms) executed with no human checkpoint remove the accountability the EU AI Act and NIST require.
Remediation	Define the set of high-risk actions and require documented human approval (HITL) before the agent executes any of them.
Mapped controls	NIST AI RMF: MANAGE-2.3, GOVERN-1.4 • ISO 42001: A.9.2 (Processes for responsible use — human oversight), A.9.3 (Objectives for responsible use of AI system) • OWASP: LLM06: Excessive Agency
HIGH AAC-DATA-02 — Lawful processing basis for PII/PHI	
Evidence	Agent can reach PII/PHI but declares no processing basis (GDPR Art.6 / HIPAA).
Business risk	If the agent can reach personal or health data — declared or not — a documented processing basis (GDPR Art.6 / HIPAA permitted use) is a hard compliance requirement.
Remediation	Record the lawful/processing basis for each sensitive data class the agent can reach, or remove that class from the agent's boundary and resources.
Mapped controls	NIST AI RMF: MAP-4.1, GOVERN-1.1 • ISO 42001: A.7.3 (Acquisition of data — data rights), A.2.3 (Alignment with other organisational policies) • OWASP: LLM02: Sensitive Information Disclosure
HIGH AAC-LOG-02 — Audit logs are tamper-evident	
Evidence	Action logs are mutable — no object-lock / immutability guarantee.
Business risk	Mutable logs can be altered post-incident, destroying evidentiary value and failing SOC 2 / ISO logging-integrity expectations.
Remediation	Store logs in an immutable/object-locked destination with retention controls and restricted delete permissions.
Mapped controls	NIST AI RMF: MEASURE-2.8, MANAGE-4.1 • ISO 42001: A.6.2.8 (AI system recording of event logs), Clause 9.1 (Monitoring, measurement, analysis) • OWASP:

HIGH	AAC-RES-01 — Input guardrails against prompt injection
Evidence	No input filtering / injection guardrail configured (OWASP LLM01).
Business risk	Prompt injection is the top LLM risk. An agent with tool access and no input filtering can be steered into unintended actions by hostile input.
Remediation	Configure input guardrails (e.g. Bedrock Guardrails) with injection/jailbreak filters and denied-topic policies scoped to the agent's role.
Mapped controls	NIST AI RMF: MEASURE-2.7, MANAGE-2.2 • ISO 42001: A.6.2.6 (AI system operation and monitoring — AI-specific threats), A.6.2.2 (AI system requirements and specification) • OWASP: LLM01: Prompt Injection
HIGH	AAC-RES-02 — Agent output validated before downstream execution
Evidence	Agent output drives downstream actions with no output validation (OWASP LLM05).
Business risk	When agent output triggers downstream actions, treating it as trusted lets a manipulated model inject commands/queries into other systems. Undeclared downstream execution is assumed present (fail-closed).
Remediation	Validate, encode, or schema-constrain agent output before it reaches downstream executors (DB, shell, API), or explicitly declare the absence of downstream execution.
Mapped controls	NIST AI RMF: MEASURE-2.7, MANAGE-2.2 • ISO 42001: A.6.2.6 (AI system operation and monitoring), A.6.2.2 (AI system requirements and specification) • OWASP: LLM05: Improper Output Handling
MEDIUM	AAC-LOG-03 — Decisions are attributable to model + version + prompt
Evidence	Log records missing attribution fields: model_id, model_version, prompt_hash.
Business risk	To govern an agent you must be able to answer 'which model, which version, on what input made this decision'. Missing attribution blocks root-cause analysis.
Remediation	Extend log schema to capture model_id, model_version, and a prompt hash on every agent action.
Mapped controls	NIST AI RMF: MEASURE-2.9, MANAGE-4.1 • ISO 42001: A.6.2.8 (AI system recording of event logs), A.4.4 (Tooling resources) • OWASP:
MEDIUM	AAC-LC-01 — Model version is pinned
Evidence	Model version not pinned (=latest) — decisions not reproducible.
Business risk	A 'latest' model reference means the decision-making system can change silently. Governance requires reproducibility of which model produced which decision.
Remediation	Pin the agent to a specific model id and version. Promote new versions only through the change-review process.
Mapped controls	NIST AI RMF: MAP-2.3, MANAGE-4.1 • ISO 42001: A.4.4 (Tooling resources — reproducibility), A.6.2.5 (AI system deployment) • OWASP: LLM03: Supply Chain
MEDIUM	AAC-LC-02 — Model/prompt changes go through review
Evidence	No change-review process for model/prompt updates (uncontrolled drift risk).
Business risk	Uncontrolled prompt/model changes are drift. A documented review gate is the AI-system equivalent of change management.

Remediation	Require documented review/approval for model and system-prompt changes before they reach production.
Mapped controls	NIST AI RMF: MANAGE-4.1, GOVERN-1.5 • ISO 42001: A.6.2.5 (AI system deployment — release criteria), A.6.1.3 (Processes for responsible design & development) • OWASP:

devops-assistant-agent

Environment: production | Assurance score: **48/100** | D - Significant exposure

6 finding(s), highest severity first:

CRITICAL	AAC-ACCESS-02 — No destructive permissions over sensitive data
Evidence	Destructive permissions (incl. wildcard supersets) on sensitive data: rds:Delete* on *
Business risk	Delete/overwrite permissions on PHI/PII/sensitive stores let an autonomous or manipulated agent cause irreversible data loss or integrity compromise. Wildcard grants count — 's3:*' is a superset of every destructive S3 action.
Remediation	Remove Delete*/Put* actions and service wildcards on sensitive resources. Grant read-only where the workflow allows; route writes through a reviewed service, not the agent.
Mapped controls	NIST AI RMF: MANAGE-2.1, MEASURE-2.6 • ISO 42001: A.9.4 (Intended use of the AI system), A.7.4 (Quality of data for AI systems) • OWASP: LLM06: Excessive Agency, LLM02: Sensitive Information Disclosure
CRITICAL	AAC-OVS-01 — Human approval gates high-risk actions
Evidence	High-risk actions run without human approval: terminate_instance, delete_database.
Business risk	High-impact actions (payments, deletions, external comms) executed with no human checkpoint remove the accountability the EU AI Act and NIST require.
Remediation	Define the set of high-risk actions and require documented human approval (HITL) before the agent executes any of them.
Mapped controls	NIST AI RMF: MANAGE-2.3, GOVERN-1.4 • ISO 42001: A.9.2 (Processes for responsible use — human oversight), A.9.3 (Objectives for responsible use of AI system) • OWASP: LLM06: Excessive Agency
HIGH	AAC-ACCESS-01 — Agent execution role avoids wildcard permissions
Evidence	Wildcard actions granted to agent role: ec2:*
Business risk	An agent role granting '*' or 'service:*' actions violates least privilege. Because agents act autonomously, an over-broad role converts a single prompt injection into arbitrary account actions.
Remediation	Scope the agent role to the explicit set of actions required for its task. Replace wildcards with enumerated actions and resource ARNs.
Mapped controls	NIST AI RMF: MANAGE-2.1, GOVERN-1.2 • ISO 42001: A.9.4 (Intended use of the AI system), Clause 8.1 (Operational planning & control) • OWASP: LLM06: Excessive Agency
HIGH	AAC-RES-02 — Agent output validated before downstream execution
Evidence	Agent output drives downstream actions with no output validation (OWASP LLM05).
Business risk	When agent output triggers downstream actions, treating it as trusted lets a manipulated model inject commands/queries into other systems. Undeclared downstream execution is assumed present (fail-closed).
Remediation	Validate, encode, or schema-constrain agent output before it reaches downstream executors (DB, shell, API), or explicitly declare the absence of downstream execution.
Mapped controls	NIST AI RMF: MEASURE-2.7, MANAGE-2.2 • ISO 42001: A.6.2.6 (AI system operation and monitoring), A.6.2.2 (AI system requirements and specification) • OWASP: LLM05: Improper Output Handling

HIGH	AAC-OVS-02 — Kill switch / pause mechanism exists
Evidence	No documented kill switch / pause mechanism for the agent.
Business risk	Operators must be able to stop a misbehaving agent immediately. No kill switch means no bounded blast radius.
Remediation	Implement and document a tested mechanism to pause/disable the agent and revoke its credentials on demand.
Mapped controls	NIST AI RMF: MANAGE-2.3, MANAGE-4.1 • ISO 42001: A.9.2 (Processes for responsible use — pause/stop conditions), A.6.2.6 (AI system operation and monitoring) • OWASP: LLM06: Excessive Agency

MEDIUM	AAC-LOG-03 — Decisions are attributable to model + version + prompt
Evidence	Log records missing attribution fields: model_version, prompt_hash.
Business risk	To govern an agent you must be able to answer 'which model, which version, on what input made this decision'. Missing attribution blocks root-cause analysis.
Remediation	Extend log schema to capture model_id, model_version, and a prompt hash on every agent action.
Mapped controls	NIST AI RMF: MEASURE-2.9, MANAGE-4.1 • ISO 42001: A.6.2.8 (AI system recording of event logs), A.4.4 (Tooling resources) • OWASP: